



MCP-Bastion

Version 2.0.0

The comprehensive open-source stack for production MCP security

MCP turned every server into an agent gateway overnight. Bastion is the firewall that makes that gateway safe to run in production: **Agent IAM**, manifest checksums, injection blocking, PII redaction, denial-of-wallet caps, live dashboard, and audit. Runs **in-process** with heuristics offline and typical overhead under **5ms** on the hot path. No third-party safety API for core pillars.

PyPI + npm + Docker on GHCR + FastMCP + TypeScript + CI validate + red-team suite. Ship today, not a roadmap.

GitHub: github.com/vaquarkhan/MCP-Bastion

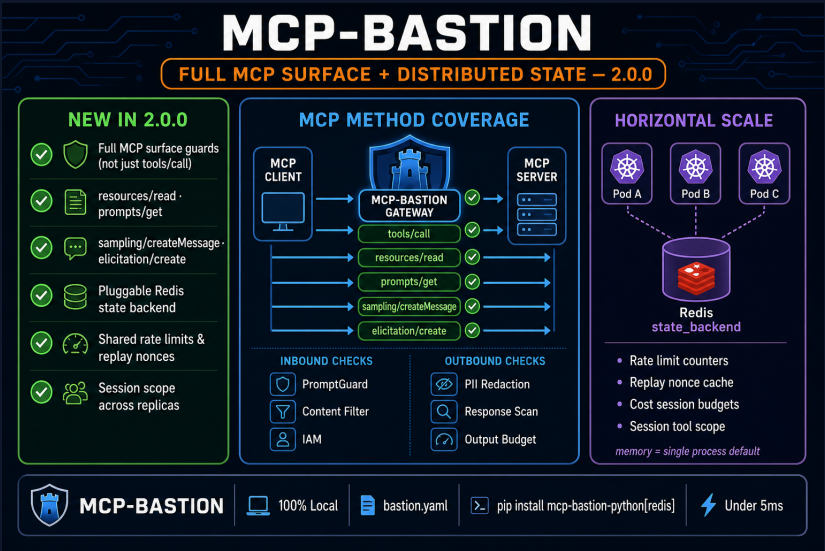
PyPI: `mcp-bastion-python==2.0.0`

Docs: vaquarkhan.github.io/MCP-Bastion

Why Teams Choose MCP-Bastion

Traditional AppSec cannot secure agentic workflows. OWASP MCP Top 10 and NSA guidance point to **runtime governance** at the protocol boundary. Bastion ships **18 request-path security features**, full MCP surface guards in 2.0.0, FinOps, and observability in a single drop-in middleware. Pair RBAC with Agent IAM or edge auth for production identity; use Redis for cross-replica rate limits and cost caps.

No rewrite	Drop-in middleware: <code>secure_fastmcp(mcp)</code> or <code>build_middleware_from_config()</code>
Privacy your legal team accepts	PromptGuard heuristics + Presidio run in your process
Stop budget burn	15 calls/session, 60s timeout, 50k token budget on by default
Cut token spend	Discovery filter, output offload (up to ~99% on huge dumps), lexical cache
Policy in Git	bastion.yaml, hot reload, doctor CLI, OWASP-aligned pillars
Scale out	Redis state_backend for shared rate limits, replay, cost caps across pods



2.0.0 guards tools/call plus resources/read, prompts/get, sampling, and elicitation. Same pillars on the full MCP surface, not just tool calls.

OWASP MCP Top 10 + Production Abuse, Addressed at the Boundary

All **10 OWASP MCP Top 10 risk categories** have mapped controls at the MCP boundary. Plus FinOps and abuse patterns OWASP does not list separately. Blocked calls surface in the dashboard, audit JSONL, and Prometheus metrics with standard error codes. Supply-chain defense is in-process manifest tamper detection, not full SCA/EDR.

MCP01 Token exposure	PII redaction, audit trail, outbound response scan
MCP02 Privilege escalation	RBAC + Agent IAM, rate limits, cost caps, session tool scope
MCP03 Tool poisoning	Prompt guard, content filter, response scan, metadata guard
MCP04 Supply chain	SHA-256 manifest checksums, doctor CLI (in-process, not sandbox)
MCP05 Command injection	Prompt guard, JSONPath argument guards, schema validation
MCP06 Intent subversion	Rate limits, replay guard, lexical similarity cache
MCP07 Weak auth	RBAC, edge auth, per-agent tokens (Agent IAM)
MCP08 Audit gap	Audit log, dashboard, Prometheus, OTEL, Slack alerts
MCP09 Shadow MCP	Central bastion.yaml policy, metrics, discovery filter
MCP10 Context injection	PII redaction, output budget, response scan, grounding guard

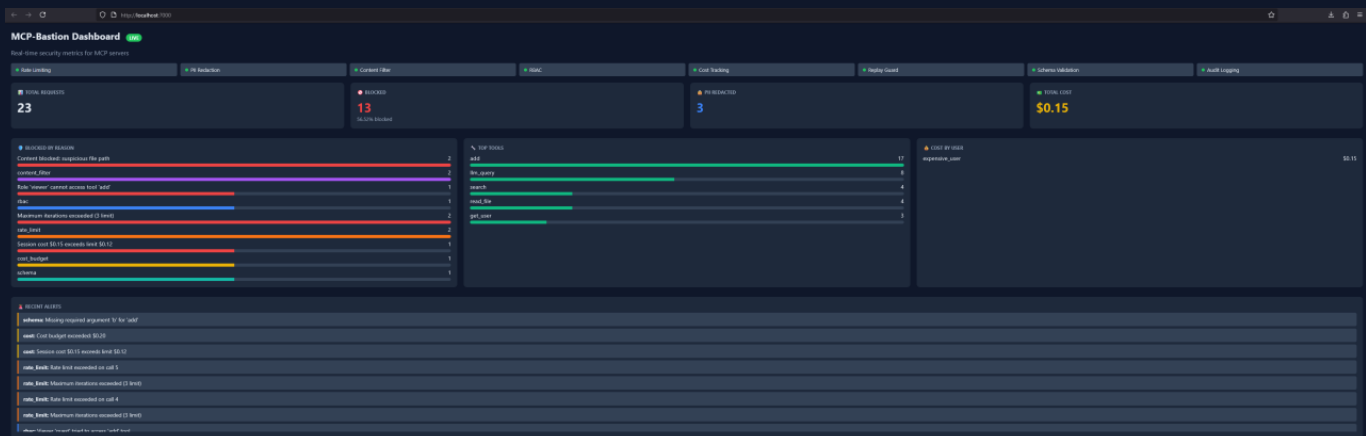
- **Denial of wallet:** iteration cap, token budget, USD session/day limits
- **Runaway loops:** session timeout, circuit breaker, per-tool caps
- **Replay abuse:** nonce tracking with Redis-backed shared state
- **Confused deputy:** token-bound agent identities and per-tool RBAC



Live Dashboard: See Every Block, Threat, and Dollar

Security without visibility is blind. MCP-Bastion ships a **real-time web dashboard** on port 7000 (CLI, Docker GHCR, or docker-compose). Every guardrail decision flows into KPIs, charts, forensics, and alerts your SOC can act on.

KPI summary	Totals, block %, top threat, active users/tenants at a glance
Traffic charts	Request volume, blocked-by-reason/kind with readable tooltips
PII forensics	PII by entity type with severity-style coloring
FinOps view	Cost by user, top tools, latency P50/P95/P99
Forensics table	Tenant filter, trace/replay helpers for incident response
Alerts	Slack webhooks, cost thresholds, recent alerts panel
Export paths	Prometheus /metrics, JSON /api/metrics, OTEL traces
Pillar health	14 dashboard rows mapped to bastion.yaml security pillars



```
mcp-bastion dashboard --port 7000|docker pull ghcr.io/vaquarkhan/mcp-bastion-dashboard:latest
```

Zero-Trust Control Plane + Get Started



Token to identity to RBAC to checksum to execute. Every agent request verified before tools, resources, or prompts run. Beyond OWASP: CSRF hardening, stdio JSON guard, multi-agent session isolation, signed manifests.

627+ pytest tests, 92% coverage, 27 pillars validated end-to-end. Heuristic PromptGuard works offline; ML depth needs gated Hugging Face access.

Install: `pip install mcp-bastion-python` | `pip install mcp-bastion-python[redis,policy,dashboard]`

Wire in: `mcp.add_middleware(build_middleware_from_config())`

- [GitHub](#) (star us)
- [PyPI 2.0.0](#)
- [Documentation](#)
- `npm @mcp-bastion/core`
- [Dashboard Docker image](#)

[Star on GitHub](#) | [Install from PyPI](#) | [Read the docs](#)